DRIFTLESS — Security Posture, Data Privacy & Reliability Analysis

1. Security Architecture & Threat Model

DRIFTLESS implements an defense-in-depth posture balancing continuous telemetry with strict data privacy:

```
graph TD
    subgraph ClientTrustBoundary["Client Boundary (Chrome Sandbox)"]
        TABS["Browser Tabs"] ⟶|Domain only (No path/DOM/query)| SW["background.js Service Worker"]
        SW ⟶|Local Key-Value Storage| STORAGE["chrome.storage.local"]
        SW ⟶|DNR Dynamic Redirects| NET["Network Layer Interception"]
    end

    subgraph TransportBoundary["Transport Layer"]
        SW ⟶|HTTPS / HTTP Authorization: Token| API_GATE["Django REST API"]
    end

    subgraph ServerTrustBoundary["Server Boundary (Django Backend)"]
        API_GATE ⟶ AUTH_GUARD["Token / Session Authentication Guard"]
        AUTH_GUARD ⟶ THROTTLE["SyncRateThrottle (120/min)"]
        THROTTLE ⟶ VALIDATOR["Serializer Input Sanitizer"]
        VALIDATOR ⟶ ISOLATION["Per-User Data Isolation Queryset"]
        ISOLATION ⟶ DB[("SQLite Database")]
    end
```

2. Authentication, Token Handling & Authorization

2.1. Dual Authentication Support

- **Web Dashboard:** Protected by Django session cookies (`SessionAuthentication`) with standard CSRF protection and HTTP-only session cookies.
- **Chrome Extension:** Authenticated using Django REST Framework's Token Authentication (`TokenAuthentication`). The extension attaches `Authorization: Token <key>` to all HTTP requests.

2.2. Token Lifecycle & Regeneration

- Upon user registration or login, an authentication token is issued from `rest_framework.authtoken.models.Token`.
- **Token Regeneration:** If a user suspects token exposure or wants to revoke an extension's access, they can trigger `/api/auth/regenerate-token/` from the dashboard. The server deletes the existing token row and generates a cryptographically random 40-character hex string. All subsequent requests using the old token immediately return `HTTP 401 Unauthorized`.

2.3. Multi-Tenant Data Isolation

Every API endpoint strictly enforces user boundaries:

```
# Verified in core/views.py and core/tests.py
user_logs = UsageLog.objects.filter(user=request.user)
site_limits = SiteLimit.objects.filter(user=request.user)
```

- In `core/tests.py` (`test_per_user_data_isolation_limits`), automated tests verify that User B cannot query, update, or delete User A's `SiteLimit` entries, returning `HTTP 404 Not Found` when attempting cross-user object access.

---

3. Data Privacy & Zero-Knowledge Browsing

3.1. Domain-Only Ingestion Policy

- DRIFTLESS collects **only** sanitized domain hostnames (`cleanDomain(url)`):
- Strip protocol (`https://`).
- Strip subdomain prefix (`www.`).
- Strip port (`:8000`), path (`/watch?v=xyz`), hash fragments, and query parameters.
- **Never Collected or Transmitted:**
- Full URLs or file paths
- Page titles or document contents
- Form inputs, cookies, or session headers
- Keystrokes, search queries, or clipboard data
- Video titles, message text, or user posts

3.2. Data Sovereignty & GDPR-Style Controls

Under `dashboard/core/views.py`:
1. **Full Archive Export (`/api/data/export/`):** Generates a complete, structured JSON archive of all records linked to the user's account (`UsageLog`, `SiteLimit`, `CategoryOverride`, `FocusSession`).

2. **Instant History Erasure (`/api/data/delete/`):** Executes an atomic purge of `UsageLog` and `FocusSession` entries, instantly zeroing screen time and analytics while leaving the account credentials intact.

---

4. Input Validation & Defense Against Injection

- **Domain Normalization:** All domain fields undergo regex sanitization in `clean_domain()` (`core/models.py:95`), stripping protocol headers and directory slashes before database insertion.
- **Time Dwell Clamping:** In `UsageLogSerializer`, incoming dwell seconds are bounded: `python if value < 0: raise serializers.ValidationError('time_spent_seconds must be non-negative.') if value > 86_400: raise serializers.ValidationError('time_spent_seconds exceeds 24 hours — likely a bug.')`
- **Limit Range Enforcement:** In `SiteLimitSerializer`, daily limit minutes must fall strictly between `1` and `1440` (24 hours).
- **ORM Protection:** All database interactions use Django's parameterized ORM querysets, eliminating raw SQL injection vulnerabilities.

---

5. Security & Reliability Findings Matrix

Category	Finding / Observation	Risk Level	Codebase Status	Recommended Action
Secrets Management	Default fallback `SECRET_KEY` in `settings.py`	Low (Dev) / High (Prod)	Hardcoded dev default if `.env` is omitted	Set unique `SECRET_KEY` in production environment variables
Debug Flag	`DEBUG` defaults to `True` in local development	Low (Dev) / High (Prod)	Configurable via `os.getenv('DEBUG')`	Ensure `DEBUG=False` on production deployments
CORS Policy	`CORS_ALLOW_ALL_ORIGINS = True`	Low	Enabled for local demo and extension sharing	Restrict to `CORS_ALLOWED_ORIGIN_REGEXES` matching extension IDs in production
Service Worker Sleep	Background worker suspends after 30s inactivity	Low	Mitigated via `chrome.alarms` and tab event listeners	Architecture handles worker sleep gracefully

Category	Finding / Observation	Risk Level	Codebase Status	Recommended Action
Offline Buffering	Uncommitted dwell deltas buffered in storage	Low	Mitigated: Buffered in `unsyncedDeltas` until connection restored	Verified; deltas sync immediately upon reconnect
Force-Quit Precision	Browser process terminated via Task Manager	Low	Uncommitted dwell since last 60s flush may be dropped	Inherent to browser extensions; acceptable wellbeing tolerance
Token Storage	API token stored in plain text in `chrome.storage.local`	Low	Standard for Chrome MV3 extensions	Protected by Chrome extension sandbox boundary